



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-5260 Gnutls: gnutls: information disclosure via heap overread in rsa key exchange

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-12
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-5260 Gnutls: gnutls: information disclosure via heap overread in rsa key exchange - Vulnerability Report

Published: 2026-06-12 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

CVE-2026-5260 GnuTLS information disclosure via heap overread in RSA key exchange

1. Executive Summary

CVE-2026-5260 is a remotely reachable heap-overread vulnerability in GnuTLS that affects the PKCS#11-backed RSA private-key decryption path used during legacy TLS RSA and RSA-PSK server handshakes. Upstream GnuTLS advisory material, the public GitLab security issue, Red Hat's CNA record, NVD, Ubuntu, and Debian all align on the same core condition: when a server uses an RSA key backed by a PKCS#11 token, an attacker can send an extremely short premaster secret in `ClientKeyExchange` and trigger an out-of-bounds read that can crash the process or leak adjacent memory.

The most important defensive nuance is that this is not a generic "all GnuTLS servers on the internet" flaw. Exposure depends on a specific deployment pattern: a GnuTLS server, using an RSA private key through PKCS#11, with vulnerable code present, and with TLS RSA or RSA-PSK handshake paths reachable. Modern TLS 1.3 deployments that use ephemeral key exchange and do not rely on PKCS#11-backed RSA server decryption are materially less exposed than legacy or compatibility-heavy environments, especially those fronting HSMs, smartcards, or PKCS#11 middleware.

Public reporting reviewed for this task did not identify confirmed in-the-wild exploitation, a public weaponized proof of concept, or CISA KEV inclusion as of 2026-06-11. Even so, the technical details are mature enough for adversaries and researchers to reproduce the issue: the public GitLab issue describes the vulnerable function, why the length mismatch occurs, and how a 0-47 byte ciphertext can trigger the overread. For defenders, the immediate priority is to upgrade to GnuTLS `3.8.13` or later, or apply downstream fixed packages such as Ubuntu and Debian backports, then identify any servers using PKCS#11-backed RSA keys and legacy RSA key-exchange compatibility.

Executive takeaway	Assessment
Business impact	At minimum, attacker-triggered process instability or denial of service is credible; limited information disclosure is also plausible because the failure mode is a heap overread in a network-reachable server path.
Most exposed environments	GnuTLS-backed servers using RSA private keys via PKCS#11 tokens or HSM middleware, especially where TLS RSA or RSA-PSK handshakes remain enabled for compatibility.
Exploitation prerequisites	The attacker needs network reachability to the vulnerable handshake path and a server configuration that uses a PKCS#11-backed RSA key.
Immediate priority	Patch to GnuTLS `3.8.13+` or vendor-fixed backports, then identify legacy handshake compatibility and PKCS#11 key usage across exposed services.

2. Intelligence Requirement

This review addresses the following intelligence requirement: what does current public reporting establish about `CVE-2026-5260`, which GnuTLS deployment patterns are actually exposed, how realistic is exploitation in enterprise environments, and what defensive actions should platform, PKI, and detection teams take next?

Question	Assessment
What is the vulnerability?	A heap overread in GnuTLS's PKCS#11-backed RSA decryption path during TLS RSA / RSA-PSK handshakes when an attacker sends an extremely short premaster secret.
What is affected?	Vulnerable GnuTLS server deployments using RSA private keys

	backed by PKCS#11 tokens and reachable legacy RSA handshake paths.
What is the likely attacker outcome?	Process crash / service instability is the most defensible immediate outcome; limited information disclosure is also plausible and explicitly reflected in the CVE description.
Is every GnuTLS deployment exposed?	No. Exposure depends on PKCS#11-backed RSA server keys and reachable RSA or RSA-PSK handshake code, not merely the presence of the library.
Is exploitation public or commoditized?	No confirmed in-the-wild exploitation or broad public weaponization was identified in reviewed sources as of 2026-06-11.
What matters most operationally?	Patch the library, identify PKCS#11-backed RSA servers, review TLS compatibility settings, and watch for service crashes or anomalous handshake failures.

3. Source Review and Confidence

Source	Contribution	Confidence
Microsoft Security Update Guide intake entry	Confirms the intake event and source chronology used to trigger this report.	Medium
GnuTLS security advisory `GNUTLS-SA-2026-04-29-10`	Primary upstream statement of vulnerability class, affected condition, and upgrade guidance to `3.8.13+`.	High
GnuTLS public issue `#1814`	Richest technical source for root cause, affected function, handshake reachability, and reproduction conditions.	High
GnuTLS `3.8.13` release announcement / oss-sec repost	Corroborates advisory language, release timing, and public dissemination of the fix.	High
CVE Program CNA JSON record (Red Hat)	Canonical publication metadata, Red Hat severity rating, CVSS vector, and vendor references.	High
NVD entry / NVD API	Normalized CVSS and CWE mapping (`CWE-1284`), plus publication history.	High
Red Hat Bugzilla `2467450`	Confirms Red Hat's public defect-tracking description and ties the issue to enterprise remediation flow.	High
Ubuntu CVE tracker / USN-8284-1	Confirms fixed backports across maintained Ubuntu releases.	High
Debian tracker / DSA-6281-1	Confirms fixed package versions for Debian supported releases.	High
Open-source and public-source exploitation review	Did not surface confirmed in-the-wild exploitation or publicly weaponized exploit tooling by review time.	Medium

Confidence is high on the existence, trigger condition, and remediation path for the vulnerability because upstream, CNA, NVD, distro trackers, and the public technical issue all describe the same flaw consistently. Confidence is also high that the vulnerable path is narrower than the raw CVSS score may imply: the bug is serious, but not equally reachable across all GnuTLS consumers.

Confidence is medium on broader enterprise exploitation likelihood because the public sources do not show active exploitation telemetry, named threat-actor usage, or commodity exploit-kit support. The risk becomes materially higher in legacy environments that still accept RSA key exchange, expose public-facing GnuTLS servers, or rely on PKCS#11-backed keys for compliance or HSM-backed deployments.

4.1 Core Vulnerability Metadata

Field	Value
CVE	`CVE-2026-5260`
Product	`GnuTLS` / `libgnutls`
Upstream advisory	`GNUTLS-SA-2026-04-29-10`
Vulnerability class	Heap overread / information disclosure / crash risk
Affected path	PKCS#11-backed RSA private-key decryption during TLS RSA / RSA-PSK server handshakes
Public issue	GnuTLS issue `#1814`
Public upstream fixed version	`3.8.13`
Red Hat severity	`Moderate`
NVD / CNA CVSS v3.1	`8.2 / HIGH`
CVSS vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:H`
NVD weakness mapping	`CWE-1284 Improper Validation of Specified Quantity in Input`
Public CVE publication	`2026-05-26`
Upstream release containing fix	`2026-04-29`
Public exploitation at review time	Not confirmed in reviewed sources
KEV status at review time	Not identified in reviewed CISA/public KEV material

4.2 Root Cause and Reachability

The public GnuTLS issue provides materially richer detail than the short CNA/NVD description. According to issue `#1814`, the vulnerable function is `\_gnutls\_pkcs11\_privkey\_decrypt\_data2()` in `lib/pkcs11\_privkey.c`. The function allocates a temporary buffer sized from `ciphertext->size`, but later performs a constant-time copy loop that reads `plaintext\_size` bytes regardless of whether the PKCS#11 decryption operation failed and returned a shorter-than-expected buffer.

This creates the core safety failure: a peer-controlled ciphertext length can become smaller than the fixed-size plaintext expectation, while the post-failure copy logic still reads beyond the temporary buffer boundary.

Root-cause element	Analyst assessment
Vulnerable function	`_gnutls_pkcs11_privkey_decrypt_data2()` in

	`lib/pkcs11_privkey.c`
Immediate flaw	Temporary buffer allocation is based on attacker-controlled ciphertext length, but subsequent copy logic assumes `plaintext_size` bytes are readable.
Why network reachability exists	Server-side TLS RSA and RSA-PSK handshake code passes a peer-controlled `ClientKeyExchange` RSA ciphertext length into the decryption path.
Exploit condition described upstream	A short ciphertext such as 0-47 bytes can reach the PKCS#11 path when packet structure is otherwise valid.
Resulting behavior	Undefined behavior, likely crash, and possible adjacent-memory disclosure via out-of-bounds read.
Security lesson	“Constant-time” handling does not guarantee memory safety if the buffer sizing assumptions feeding the loop are attacker-influenced.

4.3 Exposure and Affected Deployment Patterns

Exposure pattern	Why it matters	Confidence
GnuTLS-backed public-facing servers using PKCS#11-backed RSA private keys	This is the clearest direct exposure pattern described by upstream.	High
HSM- or token-backed TLS termination using legacy RSA compatibility	PKCS#11 middleware often exists exactly in these environments, increasing operational relevance.	High
Appliances, middleware, or internal gateways using RSA-PSK	The public issue names RSA-PSK as another reachable handshake path.	Medium
Modern TLS 1.3-only services without PKCS#11-backed RSA server decryption	These are less likely to reach the vulnerable path.	High
Generic client-only GnuTLS installations	The reviewed sources do not justify claiming equal exposure outside the specific server-side decryption path.	High

4.4 Downstream Fixed Versions

Vendor / release	Fixed version	Analyst note
Upstream GnuTLS	`3.8.13`	Primary upgrade target recommended by upstream advisory.
Ubuntu 26.04 LTS (`plucky`)	`3.8.12-2ubuntu1.1`	Marked fixed in Ubuntu tracker / USN lineage.
Ubuntu 25.10 (`questing`)	`3.8.9-3ubuntu2.2`	Marked fixed in Ubuntu tracker.
Ubuntu 24.04 LTS (`noble`)	`3.8.3-1.1ubuntu3.6`	Marked fixed in Ubuntu tracker.
Ubuntu 22.04 LTS (`jammy`)	`3.7.3-4ubuntu1.9`	Marked fixed in Ubuntu tracker.
Debian bookworm (security)	`3.7.9-2+deb12u7`	Marked fixed in DSA-6281-1.
Debian trixie (security)	`3.8.9-3+deb13u4`	Marked fixed in DSA-6281-1.

Red Hat Enterprise Linux 8	`0:3.6.16-8.el8_10.6`	Listed as unaffected/fixed state in CNA affected-product data.
Red Hat Enterprise Linux 9	`0:3.8.10-4.el9_8`	Listed as unaffected/fixed state in CNA affected-product data.
Red Hat Enterprise Linux 10	`0:3.8.10-4.el10_2`	Listed as unaffected/fixed state in CNA affected-product data.

4.5 Analyst Findings

Finding	Defensive implication
The vulnerable path is narrower than the headline CVSS suggests.	Prioritization should emphasize PKCS#11-backed RSA server deployments rather than all systems carrying `libgnutls`.
The bug is technically mature enough for targeted reproduction.	Even absent public weaponization, defenders should assume internal validation or red-team reproduction is straightforward.
Crash risk is the most credible immediate operational effect.	Availability monitoring and crash telemetry are valuable alongside patch management.
Information disclosure remains meaningful even if the overread is short.	Services handling sensitive sessions, HSM-backed keys, or privileged infrastructure should still treat the issue seriously.
Legacy handshake compatibility increases exposure.	TLS-hardening projects that disable RSA key exchange can provide real risk reduction beyond patching alone.

5. Threat Context

CVE-2026-5260 belongs to a class of cryptographic-implementation flaws where the exploitability depends less on “is the library installed?” and more on whether a specific key-management and protocol path is reachable. In this case, the combination of PKCS#11-backed RSA private keys and legacy TLS RSA or RSA-PSK handshake handling is what creates the operationally relevant attack surface.

That matters because the most exposed organizations are not necessarily those with the newest cloud-native stacks. The higher-risk population includes environments that still preserve older handshake compatibility, route TLS operations through HSMs or tokens, or use middleware that abstracts PKCS#11 in front of externally reachable services. Those are often regulated, enterprise, industrial, or long-lived infrastructure environments where maintenance windows and cryptographic modernization can lag.

The reviewed public record does not show a named threat actor, mass scanning campaign, or commodity exploitation at this time. However, the technical issue is public enough that opportunistic researchers or capable adversaries can reproduce it without needing to reverse-engineer a patch diff from scratch. For internet-facing or partner-facing legacy services using PKCS#11-backed RSA keys, the issue should therefore be handled as a realistic remote service-disruption and possible memory-disclosure risk.

MITRE ATT&CK mapping	Relevance	Confidence
`T1190` Exploit Public-Facing Application	Applicable when a public-facing service exposes the vulnerable handshake path and is attacker-reachable over the network.	Medium
`T1499` Endpoint Denial of Service	Relevant because a credible outcome is a crash or service instability triggered by	Medium

	malformed handshake input.	
`T1040` Network Sniffing / traffic collection follow-on	Low-confidence follow-on relevance only if memory disclosure or service destabilization aids traffic interception or additional credential exposure.	Low
Additional ATT&CK techniques	Not assigned with high confidence because the public reporting does not document a full post-exploitation intrusion chain.	High

6. Detection and Hunting

There are no durable public IOCs, malware hashes, or attacker infrastructure indicators associated with this CVE in the reviewed source set. The strongest defensive approach is therefore exposure-centric and behavior-centric: identify vulnerable package versions, locate servers using PKCS#11-backed RSA keys, review where TLS RSA or RSA-PSK remains enabled, and monitor for handshake-triggered crashes or repeated TLS negotiation anomalies.

6.1 Detection Coverage Summary

Signal	Telemetry source	Defensive value
Hosts with vulnerable GnuTLS versions or missing backports	Vulnerability scanners, package inventory, SBOM, container/image scanning	Best proactive exposure detection
Services configured with PKCS#11 key URIs or HSM-backed RSA private keys	Application configs, PKI/HSM inventories, deployment manifests	Highest-value scoping signal for actual reachability
TLS services still allowing RSA or RSA-PSK key exchange	TLS configuration review, scanner output, reverse-proxy / server configs	Helps separate theoretical from reachable exposure
Process crashes or restarts in GnuTLS-backed daemons during TLS negotiation	Syslog, journald, EDR process telemetry, service-monitoring logs	Best post-trigger signal
Repeated malformed or failed handshakes against exposed services	Load balancer logs, reverse proxy logs, IDS, packet capture, application debug logs	Useful for detecting probing or failed exploitation attempts

6.2 Example Detection / Hunt Content

Microsoft Defender vulnerability inventory query:

```
DeviceTvmSoftwareInventoryVulnerabilities
| where CveId == "CVE-2026-5260"
| project DeviceName, OSPlatform, SoftwareName, SoftwareVersion, VulnerabilitySeverityLevel,
RecommendedSecurityUpdate
| order by DeviceName asc
```

Microsoft Defender hunt for crash-like activity on Linux hosts after vulnerable-package identification:

```
let CrashTerms = dynamic(["segfault", "segmentation fault", "core dumped", "crash", "application
fault", "out of bounds"]);
DeviceEvents
| where Timestamp > ago(30d)
| where ActionType has_any ("Crash", "ApplicationCrash", "Fault")
    or AdditionalFields has_any (CrashTerms)
| where InitiatingProcessFileName has_any ("gnutls-serv", "stunnel", "nginx", "haproxy", "openconnect",
"apache2")
| project Timestamp, DeviceName, ActionType, InitiatingProcessFileName, InitiatingProcessCommandLine,
AdditionalFields
| order by Timestamp desc
```

Sigma review stub for Linux application logs:


```

title: Possible GnuTLS PKCS11 RSA Handshake Crash
id: 8a8dcf52-0f3f-4dca-9d17-cve-2026-5260
author: Lost Boys Cyber
status: experimental
description: Detects possible crashes or fault conditions in services that may be exercising GnuTLS
PKCS#11-backed RSA handshake code.
logsource:
  product: linux
  category: application

detection:
  selection_keywords:
    message|contains:
      - 'gnutls'
      - 'pkcs11'
      - 'ClientKeyExchange'
      - 'RSA-PSK'
      - 'RSA key exchange'
  selection_failure:
    message|contains:
      - 'segmentation fault'
      - 'core dumped'
      - 'out of bounds'
      - 'heap overread'
      - 'crash'
      - 'fatal alert'
  condition: selection_keywords and selection_failure
falsepositives:
  - Benign TLS compatibility testing
  - Lab fuzzing or negative test traffic
level: medium
tags:
  - attack.t1190
  - attack.t1499

```

Linux scoping commands for package and PKCS#11 usage review:

```

printf 'Debian/Ubuntu package view:\n'; dpkg-query -W 'libgnutls30*' 'gnutls-bin' 2>/dev/null || true
printf '\nRPM package view:\n'; rpm -qa | grep -Ei '^gnutls|^libgnutls' || true
printf '\nPKCS#11 / HSM config clues:\n'; grep -RniE 'pkcs11:|p11-kit|softhsm|opensc|engine_pkcs11'
/etc /opt 2>/dev/null | head -100

```

Threat-hunting query for services with repeated TLS-failure indicators in Splunk:

```

(index=syslog OR index=linux OR index=app_logs OR index=proxy)
("gnutls" OR "pkcs11" OR "ClientKeyExchange" OR "RSA-PSK" OR "RSA key exchange")
("segmentation fault" OR "core dumped" OR "fatal alert" OR "handshake failed" OR "crash" OR "out of
bounds")
| stats count min(_time) as first_seen max(_time) as last_seen values(host) as hosts values(process) as
processes by message
| convert ctime(first_seen) ctime(last_seen)
| sort - count

```

6.3 Hunting Guidance

Hunt question	Why it matters
Which externally reachable services use GnuTLS and PKCS#11-backed RSA keys?	This is the highest-confidence exposure set.
Which systems still permit TLS RSA or RSA-PSK handshakes for compatibility?	Reachability depends on these legacy handshake paths remaining available.
Have vulnerable systems shown recent crash loops, fatal alerts, or unexplained service restarts?	Those are plausible exploitation or reproduction side effects.

Are HSM- or token-backed services lagging behind distro backports or embedded-library updates?	Legacy crypto infrastructure often patches slower than base OS inventory suggests.
Do vulnerability-management results overstate exposure by flagging client-only or non-PKCS#11 GnuTLS consumers?	Refined scoping prevents wasted remediation effort while preserving urgency on truly exposed systems.

7. Recommendations

Priority	Owner	Action	Rationale
Critical	Platform Engineering / System Owners	Upgrade to upstream GnuTLS `3.8.13` or apply vendor-fixed backports verified to remediate `CVE-2026-5260`.	Primary remediation path confirmed by upstream and distro sources.
Critical	Vulnerability Management	Inventory all systems, containers, and appliances carrying vulnerable GnuTLS builds, then prioritize servers using PKCS#11-backed RSA keys.	Raw package presence is insufficient; reachability scoping must accompany patching.
High	PKI / HSM Operations	Identify services using PKCS#11 URIs, HSM-backed RSA server keys, or token-backed TLS termination and verify they are patched and restarted.	These are the highest-risk configurations.
High	Network / TLS Engineering	Disable legacy TLS RSA and RSA-PSK key exchange where business compatibility allows.	Reduces reachability of the vulnerable handshake path and improves crypto posture overall.
High	Detection Engineering	Add package-based exposure detection and crash / handshake-failure monitoring for GnuTLS-backed services.	There are no durable public IOCs; telemetry must focus on exposure and behavior.
Medium	Application Owners	Validate that internet-facing and partner-facing services do not silently retain embedded or statically linked vulnerable GnuTLS copies.	OS package remediation alone may not close all exposure.
Medium	Security Architecture	Review whether regulated, legacy, or HSM-backed service tiers create concentrated residual risk if modernization is delayed.	Exposure is often clustered in business-critical systems.
Medium	Threat Intelligence	Monitor for future exploit publication, KEV changes, or additional vendor advisories that alter likelihood or prioritization.	Current public reporting does not show exploitation, but that can change quickly once technical details circulate.

Additional analyst guidance:

- Treat this as both a patching issue and a cryptographic-configuration issue. Removing legacy handshake compatibility where feasible materially reduces exposure.
- Do not close remediation solely on package version if the service has not been restarted and verified to load the fixed library.
- Where HSM-backed or token-backed services are business critical and cannot be patched immediately, place them behind tighter network controls and review whether RSA handshake compatibility can be disabled temporarily.

8. References

- Microsoft Security Update Guide - CVE-2026-5260
- <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-5260>
- CVE Program API record - CVE-2026-5260
- <https://cveawg.mitre.org/api/cve/CVE-2026-5260>
- NVD CVE 2.0 API - CVE-2026-5260
- <https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-5260>
- NVD detail page - CVE-2026-5260
- <https://nvd.nist.gov/vuln/detail/CVE-2026-5260>
- GnuTLS upstream security advisory - GNUTLS-SA-2026-04-29-10
- <https://www.gnutls.org/security-new.html#GNUTLS-SA-2026-04-29-10>
- GnuTLS issue `#1814` - Remote OOB read in PKCS#11 RSA decrypt path via short ClientKeyExchange
- <https://gitlab.com/gnutls/gnutls/-/issues/1814>
- GnuTLS 3.8.13 release announcement
- <https://lists.gnutls.org/pipermail/gnutls-help/2026-April/004922.html>
- oss-sec repost of GnuTLS 3.8.13 release
- <https://seclists.org/oss-sec/2026/q2/288>
- Red Hat Bugzilla `2467450`
- https://bugzilla.redhat.com/show_bug.cgi?id=2467450
- Red Hat CVE page - CVE-2026-5260
- <https://access.redhat.com/security/cve/CVE-2026-5260>
- Ubuntu CVE tracker - CVE-2026-5260
- <https://ubuntu.com/security/CVE-2026-5260>
- Ubuntu security notice `USN-8284-1`
- <https://ubuntu.com/security/notices/USN-8284-1>
- Debian tracker - CVE-2026-5260
- <https://security-tracker.debian.org/tracker/CVE-2026-5260>
- Debian security advisory `DSA-6281-1`
- <https://security-tracker.debian.org/tracker/DSA-6281-1>